

Actividad #3

Riesgo de seguridad con innerHTML (XSS)

Vulnerabilidad identificada

El analisis del fragmento de codigo revela una vulnerabilidad de seguridad de tipo XSS (Cross-Site Scripting). Este ataque ocurre cuando datos no confiables se insertan directamente en el DOM usando innerHTML, permitiendo que el navegador interprete y ejecute etiquetas HTML y scripts maliciosos.

Por que innerHTML es peligroso en este contexto

La propiedad innerHTML procesa el contenido como marcado HTML antes de insertarlo en el documento. Si ese contenido proviene de una fuente externa no sanitizada, un atacante puede inyectar etiquetas script, manejadores de eventos como onerror u onclick, o iframes con contenido externo que se ejecutaran en el contexto del usuario.

Correccion recomendada: textContent

La solucion mas directa es sustituir innerHTML por textContent al mostrar datos proporcionados por el usuario. A diferencia de innerHTML, textContent trata el contenido como texto plano: no interpreta etiquetas HTML ni ejecuta scripts. Esto neutraliza el vector de ataque sin necesidad de bibliotecas adicionales.

Buena practica

Usar innerHTML unicamente con contenido controlado generado por el propio codigo, y textContent para cualquier dato dinamico cuyo origen no sea completamente confiable.